



Secret Note



Bối cảnh (Context)

Startup "KeepItSafe" vừa tung ra một ứng dụng ghi chú trực tuyến, quảng cáo rằng nền tảng của họ sử dụng "công nghệ điện toán đám mây" giúp người dùng chia sẻ ghi chú bí mật một cách cực kỳ an toàn. Người dùng chỉ cần đăng ký tài khoản là có thể tạo ghi chú, và mỗi ghi chú được đánh một mã ID riêng biệt.

CEO của KeepItSafe đã tạo một ghi chú đặc biệt để lưu mật mã (Flag) của kết sắt công ty. Ông tự tin rằng không ai có thể đọc được ghi chú này vì nó chỉ được gán cho tài khoản của ông.



Mục tiêu (Objective)

- **Nhiệm vụ:** Đăng nhập vào hệ thống bằng tài khoản thông thường, sau đó tìm cách đọc được nội dung ghi chú bí mật của vị CEO kia.
- **Vấn đề / Lỗ hổng:** Ứng dụng mắc phải lỗi **Insecure Direct Object Reference (IDOR)**. Khi một người dùng yêu cầu đọc ghi chú, server chỉ lấy ID từ URL hoặc tham số gửi lên để truy vấn cơ sở dữ liệu mà không thêm kiểm tra xem ID đó có thuộc quyền sở hữu của người đang gửi request hay không.
- **Flag:** Flag nằm trong nội dung của ghi chú bí mật của CEO.



Gợi ý (Hints)

- Hãy tạo một ghi chú cho riêng bạn và xem đường dẫn URL hoặc Request Headers khi bạn mở ghi chú đó.
- Chuyện gì sẽ xảy ra nếu bạn thay đổi con số (ID) trong đường dẫn thành một con số khác?